

Security

This document describes how Meridian protects your data and account, the compliance standards we hold, and how to report a vulnerability. Security is a shared responsibility: Meridian secures the platform; you secure your credentials, code, and configuration.

Shared responsibility model [sec-01]

Meridian is responsible for	You are responsible for
Physical and network security of the infrastructure	Keeping API keys and passwords secret
Encrypting data in transit and at rest	Setting appropriate roles and least-privilege scopes
Patching the platform and runtime	Application-level security in your own code
Isolating tenants from one another	Verifying webhook signatures
Availability and backups of managed resources	Choosing MFA/SSO and enforcing policies

Most real-world incidents come from the right-hand column — leaked keys and over-broad access — so start there. See [api-keys.md](#) and [account-management.md](#).

Encryption [sec-02]

- **In transit:** all traffic to Meridian APIs, dashboards, and your `*.meridian.app` URLs uses **TLS 1.2+**. Plain HTTP is redirected or rejected. TLS certificates for custom domains are provisioned and renewed automatically.
 - **At rest:** data stored by Meridian — managed databases, object storage, environment variables, build artifacts — is encrypted with **AES-256**.
 - **Secrets:** environment variables marked **secret** and API-key material are encrypted with keys managed in a dedicated key-management service and are never written to logs. Secret env vars are write-only through the API — you can set them but not read them back.
-

Authentication and access security [sec-03]

- **MFA** (TOTP and WebAuthn) is available to all accounts and can be **required** org-wide.
- **SSO** (SAML) and **SCIM** provisioning are available on Team/Enterprise.
- **Least privilege:** roles for people, scoped keys for machines. Grant the minimum needed.
- **IP allowlists** can restrict where a secret key may be used.
- **Session control:** configurable session lifetime and "sign out everywhere."

Details in [authentication.md](#) and [account-management.md](#).

Tenant isolation [sec-04]

Each organization's services run in isolated environments with network boundaries between tenants. Managed databases are provisioned per customer with unique credentials; no customer can reach another customer's compute or data. Build environments are ephemeral and destroyed after each build, so your source and secrets do not persist on shared build infrastructure.

Leaked credential handling [sec-05]

- Meridian continuously **scans public GitHub** and other public sources for exposed `msk_live_` secret keys. If we detect one, we **automatically revoke** it and email the organization owners with the source.
 - If you believe a key, password, or signing secret has leaked: **rotate or revoke it immediately** (see [api-keys.md](#)), review the audit log for unexpected activity, and enable MFA if it wasn't already on.
 - Suspect account takeover? Use **Settings** → **Security** → **Sign out everywhere**, rotate all keys, and contact security@meridian.io .
-

Compliance and certifications [sec-06]

Meridian maintains:

- **SOC 2 Type II** — annual audit of security, availability, and confidentiality controls. Report available under NDA.
- **ISO/IEC 27001** — certified information-security management system.
- **GDPR** — we act as a data processor for customer data; a **Data Processing Addendum (DPA)** is available.
- **PCI-DSS** — card payments are handled by a PCI-DSS Level 1 processor; Meridian never stores full card numbers (see [billing.md](#)).

Request reports, the DPA, or a security questionnaire from security@meridian.io or your account team. A public overview lives at <https://meridian.io/security> and real-time availability at <https://status.meridian.io> .

Infrastructure and operational security [sec-07]

- **Backups:** managed PostgreSQL is backed up daily with point-in-time recovery within the retention window; backups are encrypted.
 - **Access controls:** Meridian staff access to production is least-privilege, logged, and requires MFA; access to customer data is restricted to what's needed for support and only with appropriate authorization.
 - **Change management:** platform changes go through review and automated testing before release.
 - **Monitoring:** infrastructure is monitored 24/7; security events are alerted to an on-call team.
 - **Penetration testing:** independent third-party penetration tests are conducted at least annually, and findings are remediated on a risk-based schedule.
-

Data retention and deletion [sec-08]

- **Active data** persists as long as your account is active.

- **On resource deletion** (a service or database you delete), compute is destroyed promptly; backups of a deleted managed database are purged within **30 days**.
 - **On account closure** (see [account-management.md](#)), customer data is deleted within **30 days**, except where longer retention is legally required (for example, invoice records kept for tax compliance).
 - **Logs** containing operational metadata are retained on a rolling window (typically 30–90 days) and then purged.
 - To request deletion of specific personal data under GDPR/CCPA, contact security@meridian.io ; we honor verified requests within the timelines those regulations require.
-

Reporting a vulnerability [sec-09]

We welcome responsible disclosure and will not pursue legal action against good-faith researchers who follow this policy.

- **Email:** security@meridian.io . Encrypt sensitive reports with the PGP key published at <https://meridian.io/.well-known/security.txt> .
 - **Include:** a clear description, reproduction steps, affected endpoints/URLs, and impact.
 - **Please do:** test only against your own account/resources, use `test` -mode where possible, and give us reasonable time to fix before public disclosure.
 - **Please don't:** run denial-of-service tests, access or modify other customers' data, or use social engineering against our staff or customers.
 - **Response:** we acknowledge reports within **2 business days** and aim to provide a remediation timeline within **10 business days**. Eligible reports may qualify for a reward under our disclosure program.
-

Customer security checklist [sec-10]

- ☐ Enable MFA; enforce it org-wide if you have a team.
 - ☐ Use SSO/SCIM if available on your plan.
 - ☐ Use scoped, least-privilege API keys — one per service/environment.
 - ☐ Add IP allowlists to keys used by fixed infrastructure.
 - ☐ Rotate keys on a schedule and immediately on suspicion of leak.
 - ☐ Never commit secrets; use a secrets manager.
 - ☐ Verify every webhook signature and reject stale timestamps.
 - ☐ Review the audit log and key **Last used** timestamps regularly.
 - ☐ Assign the minimum role to each member; remove people promptly when they leave.
-

Frequently asked questions [sec-11]

Is Meridian SOC 2 compliant? Yes — SOC 2 Type II, with the report available under NDA. We also hold ISO/IEC 27001 and support GDPR (with a DPA). See [Compliance and certifications](#).

How do I report a security vulnerability? Email security@meridian.io (PGP key at [/.well-known/security.txt](#)) with reproduction steps and impact. We acknowledge within **2 business days**. See [Reporting a vulnerability](#).

Is my data encrypted? Yes — TLS 1.2+ in transit and AES-256 at rest, with secret environment variables and key material managed in a dedicated key-management service. See [Encryption](#).

How long do you keep my data after I delete it? Compute is destroyed promptly; backups of a deleted managed database are purged within **30 days**; account-closure data is deleted within **30 days** except where law requires longer (e.g. invoices). See [Data retention and deletion](#).

Do you offer a DPA / can I run a security questionnaire? Yes — request the DPA, SOC 2 report, or a questionnaire from security@meridian.io or your account team. See [Compliance and certifications](#).

What should I do if I think my account is compromised? Use **Sign out everywhere**, rotate all API keys, enable MFA, review the audit log, and contact security@meridian.io . See [Leaked credential handling](#).

Related documents

- [authentication.md](#) — MFA, SSO, sessions.
- [api-keys.md](#) — key scoping, rotation, leaked-key handling.
- [account-management.md](#) — roles, policies, audit log.
- [billing.md](#) — payment-data handling.